

Стандарты информационной безопасности

Практическое занятие № 3

Литература

Управление информационной безопасностью: учебное пособие для высшего профессионального образования / В.Т. Еременко и др. – Орел: ФГБОУ ВПО «Госуниверситет - УНПК» – 265 с.

Вопросы

1. Какая *серия стандартов* стала основоположником стандартизации систем управления ИБ?
2. Для организаций какой *сферы деятельности* применимы стандарты серии ISO / IEC 27000?
3. Каковы *отличительные черты* стандартов информационной безопасности серии ISO/IEC 27000?
4. Какой из стандартов серии ISO / IEC 27000 содержит требования к созданию, внедрению, эксплуатации, мониторингу, анализу, сопровождению и совершенствованию СУИБ?
5. В чем состоят основные *различия и сходства* стандартов ISO/IEC 27001 и ITUT X. 1051?
6. Какой из стандартов серии ISO / IEC 27000 признан *каталогом лучших практик* по ИБ?
7. В каком стандарте серии ISO / IEC 27000 содержится *руководство по внедрению* СУИБ?
8. На основании каких исходных данных может проводиться *оценка эффективности* СУИБ?
9. Можно ли проводить *аудит* или *сертификацию* на соответствие стандарту ISO/IEC 27002?
10. Каковы идеи руководства по *аудиту* СУИБ и *средств управления* ИБ, реализованных в СУИБ?
11. Почему подход к проведению *аудита систем менеджмента качества и окружающей среды* стандарта ISO/IEC 19011, можно применять для проведения внутренних аудитов СУИБ?
12. В каком стандарте серии ISO / IEC 27000 описана *инфраструктура руководства* ИБ?
13. Какой стандарт серии ISO/IEC 27000 рассматривает вопросы *управления безопасностью* сетей?
14. В чем состоят преимущества учёта требований российских и международных стандартов по управлению ИБ при *построении* СУИБ или *отдельных процессов управления* ИБ?
15. Каковы преимущества *одновременного учёта требований* стандартов, предъявляемых как к СУИБ в целом, так и к отдельным процессам, разрабатываемым в рамках СУИБ?
16. В чем состоит *сходство и различие* между стандартами на СУИБ и на процессы управления ИБ?
17. Какие методы и средства организации информационной безопасности для ИТ рассматриваются в стандартах ISO / IEC 13335 и ГОСТ Р ИСО / МЭК 13335?
18. Как оценивается ИБ ИТ согласно *стандартам* ISO / IEC 15408 и 18045 и ГОСТ Р ИСО/МЭК? Какие из рассмотренных стандартов затрагивают *аспекты анализа рисков* ИБ?
20. Каковы цели построения системы УИБ, соответствующей стандартам BS 25999 и 25777?
21. В чём заключается различие между *требованиями к системам управления непрерывностью бизнеса* и к *процессу управления непрерывностью бизнеса*?
22. Каковы основные цели следования модели PDCA при построении *процесса управления инцидентами* ИБ в соответствии с требованиями ГОСТ Р ИСО / МЭК ТО 18044?
23. Какие *тенденции* характерны для развития *стандартизации* управления ИБ в РФ?
24. В чем преимущество использования *отраслевых стандартов* на СУИБ по сравнению со стандартом ISO / IEC 27001, применимого к любой организации независимо от сферы деятельности?
25. Каково значение стандартов серии СТО БР ИББС в рамках *стандартизации* управления ИБ в РФ?
26. Какие аспекты регламентируют стандарты серии СТО БР ИББС, если говорить об *управлении* ИБ?
27. Каковы цели и задачи *стандартизации* по *организации* ИБ организаций БС РФ?
28. Каковы основные цели *проведения аудита* информационной безопасности организаций БС РФ?
29. На основе какой методики рекомендуется проводить оценку соответствия уровня ИБ организации БС РФ требованиям стандарта СТО БР ИББС–1.0?
30. Самостоятельно найдите информацию о *стандартах безопасности и защищённости* информационных систем, действующих в настоящее время.